

Day 33: Understanding SMB as an Assessor

Retrieval First

What does TCP/445 tell you?

This tells you that SMB is active on a device.

Why does 445 open not mean the server is vulnerable?

Well this is just telling you that port 445 is listening for SMB traffic. It being there doesn't automatically equal a vulnerability.

What is the difference between: port enumeration, service detection, and service-specific enumeration?

Port enumeration is scanning a device to find open ports and the services running on them, service detection reveals the service and its specific type or version, service-specific enumeration involves investigating the service on a port, typically asking questions which revolve around system hardening and vulnerabilities.

What did smbclient -L attempt to learn?

It tried to list all the shares

Authentication vs authorization?

Proving identity vs granting access based on permissions / what permissions do I have once authenticated

SMB Theory: What Is Actually Happening?

I know it from the server-administration side. \\SRV-DC01\HR ... Finance and so on...

I built: Account -> Global Group -> Domain Local Group -> SMB/NTFS permissions

Step 1: Network Reachability

When we scan for open ports on a device using Nmap, we see: 445/tcp open. This means: something is accepting SMB-related connections on TCP/445. It does not tell us: which user can authenticate, which shares exist, which files can be read, which files can be modified, whether permissions are correct, whether SMB is vulnerable.

Step 2: SMB authentication

When you connect to SMB using credentials, the server first has to determine: Who are you? AUTHENTICATION!!! MENTIONED IN SO MANY OF MY VIDEOS BY NOW....

For Alice: KEVINLAB\ahr, if her credentials are accepted: Authentication succeeded. That still does not mean: Alice has access to every share.

Step 3: Share enumeration

Now we ask: What network shares does this identity know about / get told about? That's what **smbclient -L** is useful for.

Client -> SMB Server -> "What shares are available?"

The response might include things such as: HR, Finance, Sales, IT depending on configuration and identity. However, share visible does not equal share accessible.

Step 4: Share access

When you attempt: \\SRV-DC01\HR, the server must evaluate Alice's authorization.

Guided Practical: Authenticated SMB Enumeration

Now time to answer a real security question: What can an ordinary authenticated domain user discover and access through SMB from Kali?

I'm going to use Alice (ahr), not administrator.

Part 1: List shares as Alice

Use the command: **smbclient -L //192.168.1.236 -U ahr -W KEVINLAB**

-U ahr (username) and -W KEVINLAB (Windows/domain context)

```
(nigist@kali)-[~]
$ smbclient -L //192.168.1.236 -U ahr -W KEVINLAB
Password for [KEVINLAB\ahr]:
session setup failed: NT_STATUS_PASSWORD_EXPIRED

(nigist@kali)-[~]
$ smbclient -L //192.168.1.236 -U ahr -W KEVINLAB
Password for [KEVINLAB\ahr]:
session setup failed: NT_STATUS_PASSWORD_EXPIRED

(nigist@kali)-[~]
$
```

Wow, her password expired. Going to change that using Active Directory Users and Computers interface...let's see if that fixes the problem.

```
(nigist@kali)-[~]
$ smbclient -L //192.168.1.236 -U ahr -W KEVINLAB
Password for [KEVINLAB\ahr]:
session setup failed: NT_STATUS_PASSWORD_MUST_CHANGE

(nigist@kali)-[~]
$
```

Hm. Oh, I accidentally clicked she had to change her password at next login.

```
(nigist@kali)-[~]
$ smbclient -L //192.168.1.236 -U ahr -W KEVINLAB
Password for [KEVINLAB\ahr]:

  Sharename      Type            Comment
  -----
  ADMIN$         Disk            Remote Admin
  C$             Disk            Default share
  Finance        Disk
  HR             Disk
  IPC$           IPC             Remote IPC
  IT             Disk
  NETLOGON       Disk            Logon server share
  Sales          Disk
  SYSVOL         Disk            Logon server share

Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.1.236 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Which shares are visible?

Refer to screenshot.

Does seeing Finance prove Alice can access Finance?

No.

Part 2: Connect to Alice's legitimate HR share

Use: **smbclient //192.168.1.236/HR -U ahr -W KEVINLAB**

```
(nigist@kali)-[~]
$ smbclient //192.168.1.236/HR -U ahr -W KEVINLAB
Password for [KEVINLAB\ahr]:
Try "help" to get a list of possible commands.
smb: \> ls

.                D          0   Tue Aug 11 22:33:22 2026
..               D          0   Mon Jul  6 19:41:56 2026
alice-test.txt.txt  A          0   Tue Aug 11 22:33:16 2026

15564031 blocks of size 4096. 12228326 blocks available
smb: \>
```

Part 3: Prove Alice's actual permission level

Run outside of smbclient: **echo "SMB authorization test from Kali" > alice-smb-test.txt**

```
(nigist@kali)-[~/Documents]
$ echo "SMB authorization test from Kali" > alice-smb-test.txt

(nigist@kali)-[~/Documents]
$ ls
alice-smb-test.txt
```

Reconnect to HR with smbclient.

```
(nigist@kali)-[~/Documents]
$ smbclient //192.168.1.236/HR -U ahr -W KEVINLAB
Password for [KEVINLAB\ahr]:
Try "help" to get a list of possible commands.
smb: \> put alice-smb-test.txt
putting file alice-smb-test.txt as \alice-smb-test.txt (1.7 kb/s) (average 1.7 kb/s)
smb: \> ls
.                D           0   Wed Aug 19 20:36:17 2026
..               D           0   Mon Jul  6 19:41:56 2026
alice-smb-test.txt A          33   Wed Aug 19 20:36:17 2026
alice-test.txt.txt A           0   Tue Aug 11 22:33:16 2026

15564031 blocks of size 4096. 12226522 blocks available
smb: \> █
```

I have now proven that Alice's current SMB/NTFS permissions permit file creation and write behavior in HR. Now clean up the directory.

```
smb: \> rm alice-smb-test.txt
smb: \> ls
.                D           0   Wed Aug 19 20:38:17 2026
..               D           0   Mon Jul  6 19:41:56 2026
alice-test.txt.txt A           0   Tue Aug 11 22:33:16 2026
```

Part 4: Attempt Finance as Alice

Use: **smbclient //192.168.1.236/Finance -U ahr -W KEVINLAB**

```
(nigist@kali)-[~/Documents]
$ smbclient //192.168.1.236/Finance -U ahr -W KEVINLAB
Password for [KEVINLAB\ahr]:
Try "help" to get a list of possible commands.
smb: \> ls
NT_STATUS_ACCESS_DENIED listing \*
smb: \> touch cat.txt
touch: command not found
smb: \> mkdir test
NT_STATUS_ACCESS_DENIED making remote directory \test
smb: \> █
```